Semana 01 — Panorama de la ciberseguridad y superficie de ataque

Fase 1: Fundamentos, criptografía y marco legal — instrucciones paso a paso

Prof. César Rodríguez | ELECTRONICA | 1 de noviembre de 2026

Curso	CYBERSEGURIDAD — Ciberseguridad Aplicada
Semana	01 de 10
Fase	1 — Fundamentos, criptografía y marco legal
Modalidad	4 grupos, trabajo desde sus propios equipos
Dedicación	4 horas de laboratorio + 2 horas de estudio independiente
Instrumento	Actividad formativa
Entrega	GitHub, carpeta semana_01/
Corte	Domingo 23:59 de la semana correspondiente; lo posterior no se corrige.

1 Antes de la sesión

Estas tareas se hacen en casa, antes de la práctica. Si el repositorio o el laboratorio no están listos al empezar, la sesión se va en arreglarlos y no alcanza para el informe.

1. Crear el repositorio privado del grupo en GitHub, con nombre cyberseguridad-grupo-<n>.
2. Añadir al docente como colaborador con permiso de lectura.
3. Escribir README.md con los integrantes, el rol de cada uno y la tabla de semanas.
4. Instalar Docker y nmap en el equipo, y comprobar que ambos responden al pedir la versión.
5. Clonar el repositorio y crear la carpeta semana_01 con scripts y evidencia.
6. Verificar que docker compose up -d levanta los tres contenedores del laboratorio.

2 Objetivo de la semana

Distinguir activos, amenazas y vulnerabilidades, y describir el ciclo de vida de un ataque con marcos reconocidos.

3 Contenidos que se aplican

- Tríada CIA más autenticidad, integridad y no repudio.
- Actores: oportunista, crimen organizado, insider y APT.
- Superficie de ataque, vector y cadena de explotación.
- Cyber Kill Chain y MITRE ATT&CK como vocabulario común.
- Roles rojo, azul y púrpura; modelos de amenaza STRIDE.
- Riesgo como función de probabilidad e impacto.

4 Escenario

El laboratorio tiene tres contenedores. Cada grupo inventaría puertos, servicios y versiones de su objetivo asignado, y propone tres vectores plausibles por servicio expuesto.

5 Paso a paso de la práctica

1. Levantar el laboratorio con docker compose up -d y verificar los tres servicios.
2. Enumerar puertos y servicios del objetivo asignado solo desde localhost.
3. Identificar versiones y anotar la evidencia exacta de cada hallazgo.
4. Aplicar STRIDE a cada servicio y priorizar los tres vectores más plausibles.
5. Anonimizar la evidencia y entregar la tabla con la conclusión del grupo.

Concepto clave

Regla de oro de la evidencia: guarda la salida de cada paso en `semana_01/evidencia/` en el momento en que la obtienes. Reconstruirla después no es evidencia, es memoria.

Herramientas de la semana: Docker, nmap sobre localhost, Navegador.

6 Rol de cada grupo esta semana

Todos los grupos resuelven la misma práctica, cada uno en su propio repositorio y su propio laboratorio: el trabajo de un grupo no depende del de otro. El rol cambia el énfasis del trabajo y lo que cada grupo aporta al comparar resultados en clase, al final.

Grupo	Rol	Aporte principal
Grupo 1	**Rojo**	Evidencia cruda en semana_01/evidencia y el apartado de reproducción del informe.
Grupo 2	**Azul**	La mitigación aplicada, el comando de verificación y la comparación de resultados.
Grupo 3	**Púrpura**	La regla o consulta de detección y la tabla de lo detectado frente a lo ejecutado.
Grupo 4	**Legal y reporte**	La versión final del informe y la declaración explícita de lo que no se pudo verificar.

7 Qué se entrega

Tabla de activos y servicios, modelo STRIDE y conclusión priorizada de tres vectores.

Estructura de la carpeta `semana_01/`:

- README.md con integrantes, roles y tabla de semanas entregadas.
- semana_01/informe.md o informe.pdf con el entregable de esa práctica.
- semana_01/scripts/ con el código, con type hints y docstrings.
- semana_01/evidencia/ con salidas, capturas y hashes anonimizados.
- semana_01/README.md con el resumen de lo hecho y lo que no se pudo verificar.

Reglas que se verifican al corregir:

- Nada de secretos, tokens ni contraseñas en el repositorio; las claves van en .env ignorado.
- Nada de imágenes de disco, muestras de malware ni binarios: solo hashes y enlaces.
- Evidencia anonimizada: sin datos personales de terceros ni credenciales reales.
- Un commit por entrega con mensaje "semana NN: <entregable>".
- La práctica cuenta como entregada solo si está en el repositorio antes del corte.

8 Cómo se corrige

Criterio	Peso
Cobertura completa de puertos y servicios del objetivo	3,0
Evidencia reproducible de cada hallazgo	2,5
Uso correcto del vocabulario de amenazas	2,0
Priorización justificada por impacto y probabilidad	1,5
Redacción clara y evidencia anonimizada	1,0
Total	**10,0**

9 Lista de verificación antes del corte

- El repositorio del grupo existe, es privado y el docente aparece como colaborador.
- La carpeta semana_01/ está en el repositorio, no solo en el equipo.
- El informe explica qué se hizo, con qué comandos y qué se obtuvo.
- La evidencia está anonimizada: sin datos personales, credenciales ni secretos.
- Cada hallazgo tiene su hash o su salida cruda que permite reproducirlo.
- El commit ’semana 01: <entregable>’ está hecho antes del corte.

Alcance y autorización: solo se trabaja sobre los contenedores del laboratorio o sobre sistemas con autorización escrita. Si el objetivo no está en ese conjunto, se detiene la práctica y se consulta al docente. El uso de estas técnicas fuera del alcance tiene consecuencias académicas y legales.

Recuerda

Dudas de la semana: se responden en clase o en el repositorio. Corte: Domingo 23:59 de la semana correspondiente; lo posterior no se corrige.

10 Glosario de la semana

Término	Definición
Activo	Cualquier cosa que tiene valor para el curso o para el negocio: datos, servicios, cuentas, equipos o reputación. Se protege porque perderla o exponerla tiene un costo.
Amenaza	Agente o evento con capacidad de causar daño a un activo. Puede ser oportunista, crimen organizado, insider o APT; la amenaza no es la vulnerabilidad.
Vulnerabilidad	Debilidad concreta que una amenaza puede aprovechar: un servicio sin parche, una contraseña débil, un permiso de más o un diseño sin validación.
Riesgo	Función de la probabilidad de que una amenaza explote una vulnerabilidad y del impacto que tendría sobre el activo. No es lo mismo que el impacto: se pondera con la probabilidad.
Superficie de ataque	Conjunto de puntos por donde se puede intentar entrar: puertos abiertos, servicios, interfaces, cuentas y configuraciones expuestas. Inventariarla es el primer paso de la práctica.
Vector de ataque	Camino concreto que usa el atacante para llegar al activo, por ejemplo un servicio con una versión vulnerable o una credencial por defecto.
Cadena de explotación	Secuencia de pasos que va del reconocimiento al efecto final: reconocer, obtener acceso, escalar, persistir, moverse y actuar. Un control en cualquier eslabón puede romperla.
Tríada CIA	Confidencialidad, integridad y disponibilidad: las tres propiedades que se protegen por defecto. A ellas se suman autenticidad, integridad de origen y no repudio.
No repudio	Garantía de que quien realizó una acción no puede negar haberla hecho. Se apoya en firmas, registros confiables y control de identidad.
APT	Amenaza persistente avanzada: un adversario con recursos, tiempo y objetivos concretos que opera de forma sigilosa y sostenida. No es un ataque puntual ni un script suelto.
Insider	Persona con acceso legítimo que abusa de él, por negligencia o de forma deliberada. Su ventaja es que conoce la red y no necesita romper el perímetro.
STRIDE	Modelo de amenazas con seis categorías: suplantación, manipulación, repudio, revelación de información, denegación de servicio y elevación de privilegios. Ayuda a no olvidar categorías al analizar un servicio.
Cyber Kill Chain	Modelo de siete fases del ataque, del reconocimiento a la acción final. Sirve para ubicar en qué punto se puede detectar o interrumpir cada ataque.
MITRE ATT&CK	Catálogo de tácticas y técnicas reales de adversarios, con identificadores estables. Se usa como vocabulario común para describir lo observado y lo detectado.
Equipo rojo, azul y púrpura	Rojo ejecuta la ofensiva controlada; azul defiende y mitiga; púrpura mide la detección y acerca a los otros dos. En este curso son roles de grupo que rotan por fase.
Enumeración de servicios	Descubrir qué puertos están abiertos y qué software y versión responde en cada uno. Se hace solo contra objetivos autorizados, en este laboratorio desde localhost.
Evidencia reproducible	Salida, captura o hash que permite a otra persona repetir el paso y obtener lo mismo. Una descripción sin evidencia no es un hallazgo verificable.
Localhost	La propia máquina (127.0.0.1). En el laboratorio el objetivo vive aquí, así que las pruebas no salen del equipo ni alcanzan infraestructura de terceros.